

Reflexion und kritische Analyse

Am Anfang hatten wir ehrlichen Respekt davor, eine komplette App mit Login, Datenbank und KI aufzubauen. Keiner von uns hatte vorher ein produktionsnahes Backend gebaut, und entsprechend unsicher war das Gefühl zu Beginn. Rückblickend war genau das der wertvollste Teil des Projekts. Wir mussten die App nicht nur zum Laufen bringen, sondern auch verstehen, warum sie läuft und an welchen Stellen sie angreifbar wird.

Wie ist die IT-Security?

In der Vorlesung haben wir die typischen Schwachstellen von KI-generiertem Code kennengelernt. Dazu gehören fehlende Autorisierung, SQL-Injection, hartkodierte Zugangsdaten und offene Debug-Endpoints. Wir haben versucht, diese Punkte von Anfang an bewusst mitzudenken, statt darauf zu vertrauen, dass die KI das schon richtig macht.

Was wir gut gelöst haben

- **Autorisierung über Row Level Security, nicht über das Frontend.** Für reguläre nutzerbezogene Datenzugriffe bildet die Datenbank mit Row Level Security unsere zentrale Sicherheitsgrenze. RLS ist auf allen fachlichen Tabellen aktiv und umfasst rund siebzig Policies. Reguläre Abfragen sind auf den eigenen Nutzer eingeschränkt. Filter im Frontend behandeln wir ausdrücklich nicht als Schutz. Wer die API direkt anspricht, sieht trotzdem nur seine eigenen Daten. Privilegierte serverseitige Abläufe können RLS jedoch umgehen. Dort hängt die Sicherheit zusätzlich von den Autorisierungsprüfungen in den Edge Functions und den aufgerufenen Datenbankfunktionen ab. Damit haben wir einen typischen Vibe-Coding-Fehler vermieden, nämlich die fehlende Autorisierung.
- **Keine Secrets im Code.** Die Datei mit den geheimen Werten ist von der Versionsverwaltung ausgeschlossen. Im Repository liegt nur eine Beispieldatei ohne echte Inhalte. Der sensible Service-Role-Key liegt nicht im Repository. Das lokale Tooling verwendet ihn bei Bedarf nur temporär und entfernt die temporäre Datei anschließend wieder. Der öffentliche Anon-Key darf bewusst öffentlich sein, weil die eigentliche Absicherung über RLS läuft.
- **Schutz vor SQL-Injection.** Wir arbeiten ausschließlich über den Supabase-Client und parametrisierte Funktionen. SQL-Befehle bauen wir nie als Text zusammen, wodurch wir diese Angriffsfläche deutlich reduzieren.
- **Solide Grundlagen bei der Anmeldung.** Die Bestätigung per E-Mail ist Pflicht und für Passwörter gilt eine Mindestlänge. Der Schutz von Sitzungen und Routen läuft serverseitig über den Proxy und nicht nur über ein Flag im Frontend.
- **Private Dateien.** Uploads liegen in einem privaten Storage-Bucket mit nutzerbezogenen Policies und einem festen Ablauf für das Aufräumen. Für diesen Bereich gibt es eigene Datenbanktests.
- **Automatisierte Kontrolle.** Die wichtigsten Prüfungen laufen automatisiert über die CI, dazu gehören Stil, Tests, Datenbankprüfungen und ein frischer Build.

- **Weitere technische Absicherungen.** Für zentrale RLS-Regeln bestehen automatisierte Datenbanktests, Stripe-Webhooks werden vor der Verarbeitung anhand ihrer Signatur geprüft und das Frontend setzt zusätzliche Security-Header.

Wo wir ehrlich noch Lücken sehen

- **Kein echter Penetrationstest.** Unser Sicherheitsblick bestand vor allem aus gegenseitigem Code-Lesen und gezielten Nachfragen an die KI. Das ersetzt keinen strukturierten Test.
- **Threat Modeling nur im Kopf.** Mögliche Angriffswege haben wir mitgedacht, aber nicht sauber dokumentiert. Für ein echtes Produkt würden wir das vorher aufschreiben.
- **Missbrauchs- und Kostenkontrolle noch nicht vollständig.** Für den KI-Chat bestehen inzwischen Pro-Nutzer-Limits pro Minute sowie eine Begrenzung gleichzeitig laufender Antworten. Damit ist ein grundlegender Schutz vorhanden. Noch fehlen jedoch ein übergreifendes Tages- oder Kostenbudget sowie ein Schutz gegen Missbrauch über viele verschiedene Konten. Die Geschichte aus der Vorlesung mit der versehentlichen Rechnung in Millionenhöhe zeigt, wie schnell ein offener KI-Endpoint teuer werden kann.
- **Prompt-Injection über hochgeladene Dokumente.** Inhalte aus Dokumenten werden als Kontext an das Sprachmodell weitergegeben. Manipulierte oder ungewöhnliche Inhalte könnten deshalb versuchen, die vorgesehenen Instruktionen des Assistenten zu beeinflussen. Dokumentinhalt muss daher grundsätzlich als nicht vertrauenswürdiger Input behandelt werden.
- **Datenschutz bei externen KI-Diensten.** Für KI-Funktionen können Lernmaterialien oder Nutzerfragen an externe Anbieter übertragen werden. Für einen produktiven Einsatz müssen deshalb Datenminimierung, Zweckbindung und die konkrete Datenverarbeitung durch die eingesetzten Anbieter bewusst geprüft werden.
- **Abhängigkeit von externen Diensten.** UniVerse ist von mehreren externen Diensten abhängig, insbesondere von Supabase sowie den eingesetzten Diensten für Zahlung und KI (Stripe und Gemini). Preisänderungen, Ausfälle oder Änderungen an Schnittstellen können deshalb direkten Einfluss auf das Produkt haben. Für ein Studienprojekt ist das in Ordnung, für ein echtes Startup wäre diese Abhängigkeit ein eigener Risikopunkt.

Unterm Strich halten wir die Sicherheitsbasis für solide, gerade weil die Autorisierung von Anfang an in der Datenbank liegt. Perfekt ist sie nicht, aber wir können zu jeder Entscheidung sagen, warum wir sie so getroffen haben.

Was haben wir gelernt?

- **KI ist ein schneller Junior, kein Senior.** Sie liefert in Minuten etwas Lauffähiges, hinterfragt Entscheidungen nicht zuverlässig und warnt nicht automatisch vor schlechten Ideen. Vorangekommen sind wir erst, als wir selbst geplant und die KI gezielt zur Umsetzung genutzt haben.
- **Review ist der eigentliche Skill.** Code erzeugen ist leicht geworden. Ihn zu lesen, zu verstehen und Schwachstellen zu finden ist die eigentliche Arbeit und genau das, was am Ende wirklich hängen bleibt.

- **Erst Architektur, dann Prompt.** Unsere besten Ergebnisse entstanden, wenn wir vorher über Frontend, Backend und Datenmodell nachgedacht haben. Ohne Plan beginnt der Code zu wuchern.
- **Sicherheit gehört von Anfang an dazu.** Die Regeln früh in die Datenbank zu legen war viel einfacher, als Autorisierung später nachzurüsten.

Was würden wir anders machen?

- **Scope früher eingrenzen.** An einigen Stellen haben wir mehr angefangen, als wir am Ende sauber fertig bekamen. Weniger Funktionen, dafür vollständig und rund, wäre die bessere Wahl gewesen.
- **Tests und CI ab Tag eins.** Wir haben beides erst später ernst genommen. Früher wäre vieles stabiler und schneller gelaufen.
- **Entscheidungen direkt dokumentieren.** Einiges mussten wir im Nachhinein rekonstruieren, weil wir nicht festgehalten hatten, warum wir einen bestimmten Weg gewählt haben.
- **Fester Security-Durchgang.** Statt Sicherheit nebenbei mitlaufen zu lassen, würden wir einen festen Termin einplanen, mit einem übergreifenden Kostenbudget für die KI-Funktionen und einem kleinen, bewussten Test zum Abschluss.

Das größte Learning ist eigentlich simpel. Vibe Coding macht uns schnell, aber nicht automatisch gut. Gut werden wir erst dadurch, dass wir verstehen, was dort entstanden ist, und den Mut haben, es auch wieder infrage zu stellen.